Sri Lanka Institute of Information Technology

B.Sc. Honours Degree in Information Technology

Specialized in Information Technology

Final Examination
Year 3, Semester 2(2019)

IT3070 - Information Assurance and Security

Duration: 2 Hours

October 2019

Instructions to Candidates:

- This paper is preceded by 10 minutes reading period. The supervisor will indicate when answering may commence.
- This paper has 4 questions.
- Answer all questions in the booklet given.
- The total marks for the paper is 100.
- This paper contains 4 pages, including the cover page.
- Electronic devices capable of storing and retrieving text, including calculators and mobile phones are not allowed.

Question 1 (25 marks)

a) Differentiate between vulnerability, threat and risk with the use of suitable examples for each.

(6 marks)

b) You are hired as a Moodle administrator to look after Learning Management System (LMS) of a large university. Recommend two physical, two technical and two administrative controls to protect hardware, data and application associated with the LMS.

(6 marks)

c) Assess the impact of data loss for an organization dealing highly sensitive business critical data using information system such as a financial institution.

(3 marks)

d) "Even when everyone acknowledges that a computer crime has been committed, computer crime is hard to prosecute".

Do you agree with this statement? Justify your answer by explaining why the statement is correct or incorrect.

(4 marks)

e) Analyse the type of protection provided and the difficulty of enforcing the following in computer software.
   i) Copyrights
   ii) Patents
   iii) Trade secrets

(6 marks)

Question 2 (25 marks)

a) Use the simple mono-alphabetic crypto system given below based on a shift cipher and answer the questions.

A	B	C	D	E	F	G	H	I	J	K	L	M
0	1	2	3	4	5	6	7	8	9	10	11	12
N	O	P	Q	R	S	T	U	V	W	X	Y	Z
13	14	15	16	17	18	19	20	21	22	23	24	25

- Encryption: $y_i = x_i + K_i \bmod 26$
- Decryption: $x_i = y_i - K_i \bmod 26$

i) Decrypt the cipher-text 'MBBXQ' using Key (Ki) = 12

(6 marks)

ii) Describe how an attacker (with no prior knowledge of the key) can break a similar cipher-text using 'Brute Force' approach.

(4 marks)

iii) Describe the best approach for an attacker (with no prior knowledge of the key) to break a similar large cipher-text.

(4 marks)

b) Using a diagram explain how 'Public key cryptography' can be used to solve the key distribution problem in symmetric cryptography.

(4 marks)

c) "Certificate Authority (CA) is a trusted third-party entity that issues certificates in Public Key Infrastructure (PKI)."

i) A single CA for certificate issuing is not a scalable solution. Explain how this problem is addressed in PKI.

(4 marks)

ii) What is the purpose of 'Certificate Revocation List' with respect to PKI?

(3 marks)

Question 3 (25 marks)

a) Differentiate between Discretionary Access Control (DAC) and Mandatory Access Control (MAC).

(4 marks)

b) Differentiate between access control list and a capability ticket.

(4 marks)

c) Workstation hijacking is a situation where the attacker waits until a logged-in workstation is unattended in order to get unauthorised access to the system and use its data and functionalities. Recommend two controls to prevent such from happening.

(4 marks)

d) A University has different systems/applications such as learning management system, IT help desk, lab machine login, internet login, etc which requires separate login each time using separate accounts. Authentication, authorisation and accounting is handled separately in each system.

i) There is a proposal to provide a Single Sign-On (SSO) system. Evaluate the proposed solution by analysing the security and administrative perspectives.

(4 marks)

ii) If a SSO system is implemented, justify the importance of using strong multifactor authentication mechanism for it.

(3 marks)

e) Using an example, explain the applicability of simple security property and *(star)-property rule of Bell-La Padulla (BLP) security model.

(6 marks)

Question 4 (25 marks)

a) "Cryptographic hash functions take an arbitrarily length of clear text data to be hashed and it produces a fixed length message digest (hash value)."

Assess two security properties required of hash functions.

(4 marks)

b) Differentiate between simple packet filtering and Stateful packet inspection.

(6 Marks)

c) "Unified threat management (UTM) is an approach to information security where a single hardware or software installation provides multiple security functions." State four services usually offered by a UTM.

(4 Marks)

d) State one advantage and one disadvantage of using 'Virtual Private Network (VPN) - Tunnelling'.

(4 marks)

e) Read the following case study and answer the questions.

"A medium-sized company has to prepare itself in facing global market that is by ensuring the continuity of its business at the time a disaster occurred. However, there are some obstacles, which make the company hesitate to create its business continuity and disaster recovery planning. To obtain information needed on company's current conditions, and readiness in preparing its business continuity and disaster recovery plan, a qualitative approach was used, which involving observation and interview.
According to budgetary restrictions, the strategy applicable for the company's current stage is a cold site strategy with the implementation of creating backups of all critical data."

i) Briefly explain the 'Cold Site' strategy mentioned in the case study.

(3 Marks)

ii) Recommend two alternative approaches the company can consider.

(4 Marks)

-- End of the Question Paper --